Stop/Djvu ransomware analysis report

using Palo Alto's Cortex XDR in a Windows environment

SOC Analyst course, FastWeb Digital Academy

Author: ndujamisu

Table of contents

Summary 2
Artifact analysis 3
Attack timeline and causality chain analysis 4
[2026-04-03 17:07:26] User-initiated extraction of malicious archive 4
[2026-04-03 17:07:30] Malicious payload execution 5
[2026-04-03 17:08:00] Process hollowing via remote PE injection 5
[2026-04-03 17:08:03] Victim host profiling via IP geolocation 6
[2026-04-03 17:08:05] Persistence mechanisms established 7
Scheduled task creation 7
Registry based autorun 8
[2026-04-03 17:08:12] Privilege escalation via UAC prompt 9
[2026-04-03 17:09:25] Elevated process injection and persistence hardening 9
[2026-04-03 17:09:45] Retrieval of public key and victim identifier 10
[2026-04-03 17:14:48] File encryption phase 10
Conclusion 11

Summary

- Host information: `Desktop-dppbi1v` (`192.168.122.9`)
- User context: `mario` (SID `S-1-5-21-743246902-2707838880-1491064362-1001`)
- Network indicators
  - `188.114.97.7` (geolocation API)
  - `198.135.84.22` (C2 infrastructure)
- Key artifacts observed by Cortex XDR
  - Malicious components
    - `d148…0701.exe` (*Stop/Djvu* dropper)
    - `_readme.txt` (ransom note)
    - `bowsakkdestx.txt` (public RSA key)
    - `PersonalID.txt` (victim identifier)
  - Legitimate processes
    - `explorer.exe` (user-initiated extraction)
    - `7zG.exe` (archive extraction)
    - `icacls.exe` (ACL manipulation)
    - `consent.exe` (UAC prompt handling)
  - Cortex XDR's honeypot ransomware decoy file
    - `ZZZZZ3591597036.doc`

Artifact analysis

- `d148dedc9b654f78a2ddd2298663df99d57d00cdec9e97a3722496cc51c60701.exe`
  - MD5: `cdc4132b29e414f192431cf17c959a56`
  - SHA256: `d148dedc9b654f78a2ddd2298663df99d57d00cdec9e97a3722496cc51c60701`
  - Signature: Unsigned
  - Location: `C:\Users\mario\Desktop\d148…0701.exe`
  - Details: this executable is flagged as malware by both VirusTotal and WildFire. The hash corresponds to the *Stop/Djvu* ransomware family (malware that infects the system and encrypts user files to demand a ransom for the decryption key). WildFire specifically reports discrepancies between real and virtual size, high entropy, and non-standard headers — all typical characteristics of packed/obfuscated executables (legitimate techniques often used to hinder reverse engineering, but also widely adopted by malware).
- `icacls.exe`
  - MD5: `2e49585e4e08565f52090b144062f97e`
  - SHA256: `468f69606e8f341b8822d20f6557cc1c2be1ba61ffbc47988540c8674f46017b`
  - Signature: Signed by Microsoft Corporation
  - Location: `C:\Windows\SysWOW64\icacls.exe`
  - Details: legitimate Windows process used to manage, save, and restore permissions and integrity levels on files and folders.
- `consent.exe`
  - MD5: `5d630c63f6f31700676e856b5ff47b26`
  - SHA256: `7084382b4c73176af091fd5082c64f9ace71e19b7be31a08ca357f427e4dc2e9`
  - Signature: Signed by Microsoft Corporation
  - Location: `C:\Windows\System32\consent.exe`
  - Details: legitimate Windows process used for handling User Account Control (UAC) prompts.
- `explorer.exe`
  - MD5: 24ad59abaf730e71bc865922d8596008
  - SHA256: `988a56d897915315eef9ca679b3bc8adfcecf5e227aea99aaa1817620520e97e`
  - Signature: Signed by Microsoft Corporation
  - Location: `C:\Windows\explorer.exe`
  - Details: legitimate Windows process used for managing the graphical user interface (GUI).
- `7zG.exe`
  - MD5: `7af0144c0b48041fb57b2aa06f15eaf2`
  - SHA256: `ac0c131e4c1ed58301a3afb44c339a2648c8d7f6e6d5d729a57d7a01c540deec`
  - Signature: Unsigned
  - Location: `C:\Program Files\7-Zip\7zG.exe`
  - Details: although the file lacks a digital signature, its hash corresponds to the legitimate binary of the 7-Zip GUI module, a well-known open-source archiving and compression tool.

- `ZZZZZ3591597036.doc`
  - SHA256: `08b454fbe77ad0ee8979e626ce488caba14a675c3126a7a1b4b35285adfdd9af`
  - Signature: Not applicable
  - Location: `C:\ProgramData\Cyvera\Ransomware\12911156673898091673`
  - Details: there is limited information available about this file, but according to discussions on the Palo Alto community forum, it appears to be a "decoy" or honeypot file deployed by Cortex XDR for ransomware detection purposes.
- `_readme.txt`
  - SHA256: `72d0caa6aae569a466efd15cae950b5433368da6e17b9bcee8ea390d329e48b1`
  - Signature: Not applicable
  - Location: multiple locations, including `C:\Users\mario`
  - Details: Again, information is limited, but Threat Intelligence sources suggest that this file is the ransomware "ransom note" — the document informing the user of the infection and providing payment instructions to obtain the decryption key.

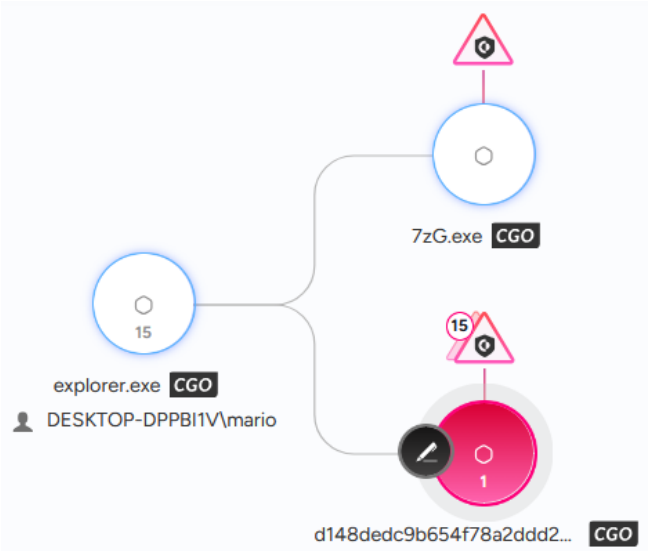
Attack timeline and causality chain analysis

`[2026-04-03 17:07:26]` User-initiated extraction of malicious archive

Analyzing the behavior of the process `7zG.exe`, the following observations can be made:

- its Process ID (PID) is *7620*;
- it runs with integrity level *8192* (Medium) and with the following parameters:
  `x -o"C:\Users\mario\Desktop\" -an -ai#7zMap6029:186:7zEvent26283`
  where:
  - `x` indicates the extraction operation;
  - `-o` specifies the destination folder;
  - `-an` indicates that the archive name was not explicitly provided via command line;
  - `-ai…` represents an internal IPC reference used by the 7-Zip GUI;

  The parent–child relationship (`explorer.exe` → `7zG.exe`) strongly indicates that the extraction was triggered manually by the user via GUI interaction – most likely via the Windows context menu (right-click → "*Extract…*"), rather than through automated or script-based execution.



- the process extracted from the archive `d148…0701.zip`, located on the user's Desktop, the executable `d148…0701.exe` into the same directory.

This step represents the initial infection vector, where the user unknowingly extracted a malicious payload from a ZIP archive, enabling subsequent execution of the ransomware.

[2026-04-03 17:07:30] Malicious payload execution

The executable extracted in the previous step is launched, marking the beginning of the ransomware execution chain. This corresponds to MITRE ATT&CK tactic *TA0002* (Execution), technique *T1204.002* (User execution: Malicious file).

Process details:

- PID *8812*;
- initial Thread ID (TID): *4236*;
- integrity level *8192* (Medium).

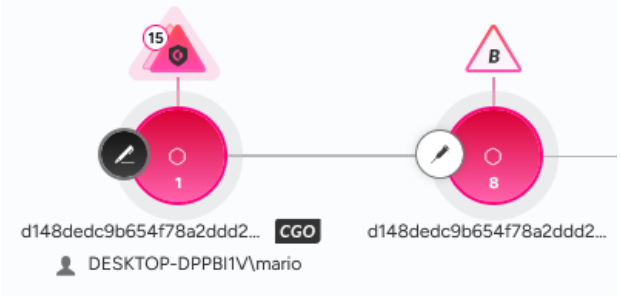
[2026-04-03 17:08:00] Process hollowing via remote PE injection

Shortly after execution, the malware performs process hollowing, a defense-evasion technique where some process memory is replaced with malicious code.

Process hollowing is a hallmark of *Stop/Djvu* ransomware variants and enables execution while evading AV/XDR detection.

Creation of suspended child process

- the original process (PID *8812*) spawns a second instance of itself:
  - PID *8596*
  - TID *5440*
  - integrity: *Medium*
  - state: suspended;
- The parent process (PID *8812*) begins writing operations into the child's virtual memory.



Memory manipulation

Two main `WriteProcessMemory` operations are observed:

- PE header injection
  - Size: 1024 bytes
  - Address: *4194304* (*0x400000*)

  This address corresponds to the default image base of Windows PE executables and contains the PE headers (DOS header, NT headers, section table);
- PE sections injection
  - Size: 828,928 bytes
  - Address: *4198400* (*0x401000*)

  This address represents the page immediately following the headers and contains the PE sections (`.text`, `.data`, `.rdata`), i.e., the actual executable content.

This sequence reconstructs a new PE image inside the suspended process.

Thread context hijacking

A thread (TID *8592*) in the child process is modified via `SetThreadContext`, redirecting the instruction pointer to address *1996904384* (*~0x77000000*), the entry point of the injected payload.

Once resumed, execution continues from the injected code rather than the original executable.

System calls involved

- `NtUnmapViewOfSection`
- `NtAllocateVirtualMemoryRemote`
- `NtWriteVirtualMemoryRemote`
- `NtSetContextThreadRemote`

MITRE ATT&CK classification

- *TA0005* (Defense evasion)
  - *T1055* (Process injection)
    - *T1055.002* (PE injection)
    - *T1055.012* (Process hollowing)

`[2026-04-03 17:08:03]` Victim host profiling via IP geolocation

The malware initiates an outbound connection to `188.114.97.7`, a host flagged as *untrusted* by multiple CTI sources (VirusTotal, AbuseIPDB, Cisco Talos). Despite this reputation, the associated hostname (`api.2ip.ua`) belongs to a legitimate IP geolocation service.

A small data transfer (5 KB) is observed, consistent with a JSON-formatted geolocation response. Additional telemetry reinforces this interpretation:

- the malware loads `wininet.dll`, the Windows API used for HTTP(S) communication;
- a file named `geo[1].json` is written to the INetCache directory shortly after the connection, indicating that WinINet cached the server's response.

These indicators strongly suggest that the malware queries a geolocation API to determine the public IP's country, ISP, and network characteristics.

Purpose of geolocation

Geolocation is a common technique used by malware to:

- detect sandbox or analysis environments
- identify known research networks
- tailor or suppress malicious behavior based on geographic or infrastructural indicators

In the case of *Stop/Djvu*, previous analyses have identified country codes such as `RU` (Russia) and `BY` (Belarus) embedded in the source code. If the geolocation response returns one of these values, the malware self-terminates, avoiding execution in regions associated with its operators.

MITRE ATT&CK classification

- *TA0043* (Reconnaissance)
  - *T1592* (Gather victim host information)

Conclusion

Geolocation checks are a key anti-analysis mechanism, enabling the malware to evade execution in controlled or high-risk environments. The presence of country-based execution logic indicates deliberate operator intent and suggests region-specific targeting or self-protection.

[2026-04-03 17:08:05] Persistence mechanisms established

The malware deploys **multiple, redundant persistence mechanisms** to ensure continuous execution and resilience against removal.

Scheduled task creation

The malware creates a hidden working directory:
`C:\Users\mario\AppData\Local\78da9cc2-5df4-4882-ab3d-3133e0368c57`
and copies itself inside it.

To harden the directory against removal, it applies restrictive ACLs:
`icacls "<folder>" /deny *S-1-1-0:(OI)(CI)(DE,DC)`

This denies the *Everyone* group (`S-1-1-0`) the ability to delete the folder (`DE` = *Delete*) or its contents (`DC` = *Delete Child*), obstructing manual cleanup and non-privileged remediation. In particular:

- `OI` (*Object Inherit*): applies the rule to subordinate files
- `CI` (*Container Inherit*): applies the rule to subordinate folders

which cause the deny ACE to be inherited by child files and subfolders.

It then registers a scheduled task via an RPC call to the `ITaskSchedulerService` interface (*UUID* `86D35949-83C9-4044-B424-DB363231FD0C`), passing this configuration:


```
{
  "xml": "<?xml version=\"1.0\" encoding=\"UTF-16\"?>
  <Task version="1.2"
        xmlns=\"http://schemas.microsoft.com/windows/2004/02/mit/task\">
    <RegistrationInfo>
      <Author>Author Name</Author>
    </RegistrationInfo>
    <Triggers>
      <TimeTrigger id=\"Trigger1\">
        <Repetition>
          <Interval>PT5M</Interval>
          <StopAtDurationEnd>false</StopAtDurationEnd>
        </Repetition>
        <StartBoundary>2026-04-03T21:01:25</StartBoundary>
        <EndBoundary>2030-05-02T08:00:00</EndBoundary>
        <Enabled>true</Enabled>
      </TimeTrigger>
    </Triggers>
    <Settings>
      <MultipleInstancesPolicy>IgnoreNew</MultipleInstancesPolicy>
      <DisallowStartIfOnBatteries>true</DisallowStartIfOnBatteries>
      <StopIfGoingOnBatteries>true</StopIfGoingOnBatteries>
      <AllowHardTerminate>true</AllowHardTerminate>
      <StartWhenAvailable>true</StartWhenAvailable>
      <RunOnlyIfNetworkAvailable>false</RunOnlyIfNetworkAvailable>
      <IdleSettings>
        <Duration>PT10M</Duration>
        <WaitTimeout>PT5M</WaitTimeout>
        <StopOnIdleEnd>true</StopOnIdleEnd>
        <RestartOnIdle>false</RestartOnIdle>
```

```
      </IdleSettings>
      <AllowStartOnDemand>true</AllowStartOnDemand>
      <Enabled>true</Enabled>
      <Hidden>false</Hidden>
      <RunOnlyIfIdle>false</RunOnlyIfIdle>
      <ExecutionTimeLimit>PT72H</ExecutionTimeLimit>
      <Priority>7</Priority>
    </Settings>
    <Actions>
      <Exec>
        <Command>
          C:\\Users\\mario\\AppData\\Local\\78da…8c57\\d148…0701.exe
        </Command>
        <Arguments>--Task</Arguments>
      </Exec>
    </Actions>
  </Task>",
  "path": "Time Trigger Task",
  "sddl": "",
  "pCreds": "MISSING"
}
```


The task is stored under:
`C:\Windows\System32\Tasks\Time Trigger Task`
and configured to run **every 5 minutes**, invoking:
`svchost.exe -k netsvcs -p -s Schedule --Task`

This high-frequency trigger ensures rapid re-execution of the payload even after termination or system instability.

The presence of the `--Task` argument indicates internal branching logic within the malware.

Registry based autorun

The malware also establishes user-level autorun persistence by modifying:
`HKCU\Software\Microsoft\CurrentVersion\Run`
adding:
`SysHelper = "C:\Users\mario\AppData\Local\78da…8c57\d148…0701.exe" --AutoStart`

`SysHelper` is not a legitimate Windows component: it's a label chosen as a masquerading technique to blend into legitimate system utilities.

Because the modification occurs under `HKCU` (`HKEY_CURRENT_USER`), it:

- does not require administrative privileges;
- applies only to the current user (`mario`), not the whole machine (`HKLM`);
- ensures execution at every logon (Windows automatically processes all values under the `Run` key)

The `--AutoStart` argument suggests a dedicated execution mode for startup scenarios.

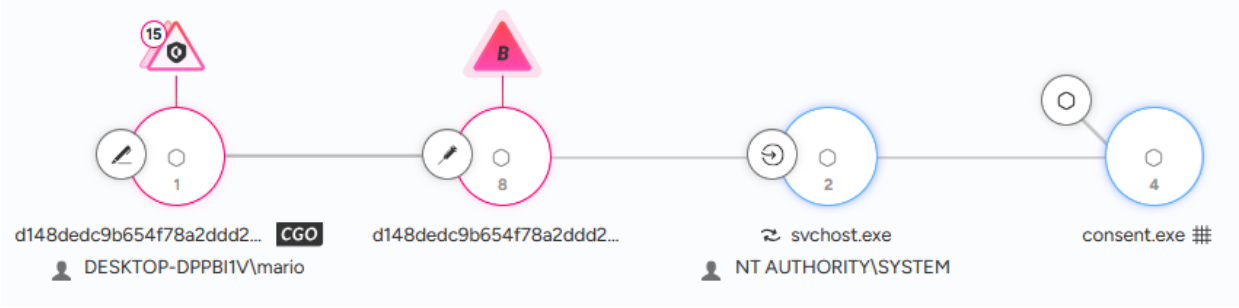
MITRE ATT&CK classification

L'attività osservata rientra nelle seguenti categorie:

- *TA0003* (Persistence)
  - *T1053.005* (Scheduled task/job creation)
  - *T1112* (Modify registry)
  - *T1547.001* (Boot or logon autostart execution: Registry Run keys / startup folder)
- *TA0005* (Defense evasion)
  - *T1036.005* (Masquerading: Match legitimate resource name or location)

The use of both scheduled tasks and `Run`-key autorun provides layered, redundant persistence, significantly increasing the malware's survivability.

`[2026-04-03 17:08:12]` Privilege escalation via UAC prompt



The malware, initially running with *Medium* integrity, triggers a UAC elevation request. The request is processed by "`svchost.exe -k netsvcs -s Appinfo`", which launches `consent.exe`, the Windows component responsible for displaying UAC prompts.

Upon user approval, the malware relaunches itself with:

- PID *2204*
- integrity level 12288 (*High*) – administrator privileges
- execution parameters: `--Admin IsNotAutoStart IsNotTask`

The `--Admin` flag indicates that the malware contains distinct execution branches depending on privilege level.

`[2026-04-03 17:09:25]` Elevated process injection and persistence hardening

Once elevated, the malware performs a second round of process hollowing, injecting into a new instance of itself (PID *8616*, *High* integrity).

It then recreates the scheduled task with modified settings, including

- `<WakeToRun>false</WakeToRun>`
- additional security descriptors (not visible in telemetry) likely intended to restrict access and prevent removal by non-privileged users.

In parallel, the malware updates the `SysHelper` `Run`-key value, replacing the executable path with the integer `1`. This suggests that after establishing privileged scheduled-task persistence, the `Run` key is repurposed as an internal state flag, or a disabled fallback mechanism, reducing visibility and avoiding redundant execution.

These actions represent a persistence hardening phase, where the malware strengthens its foothold and adapts its mechanisms to its elevated privilege level.

`[2026-04-03 17:09:45]` Retrieval of public key and victim identifier

The malware contacts its C2 server at `198.135.84.22` (`cajgtus.com`) and downloads two critical files:

- `C:\Users\mario\AppData\Local\bowsakkdestx.txt`
  Contains the public RSA key used to encrypt victim files;
- `C:\SystemID\PersonalID.txt`
  Contains the unique victim identifier, used by operators to track infections and manage decryption keys/payments.

Threat Intelligence sources and VirusTotal confirm that `cajgtus.com` is part of *Stop/Djvu*'s malicious infrastructure.

MITRE ATT&CK classification

- TA0011 (Command and control)
  - T1071 (Application layer protocol)

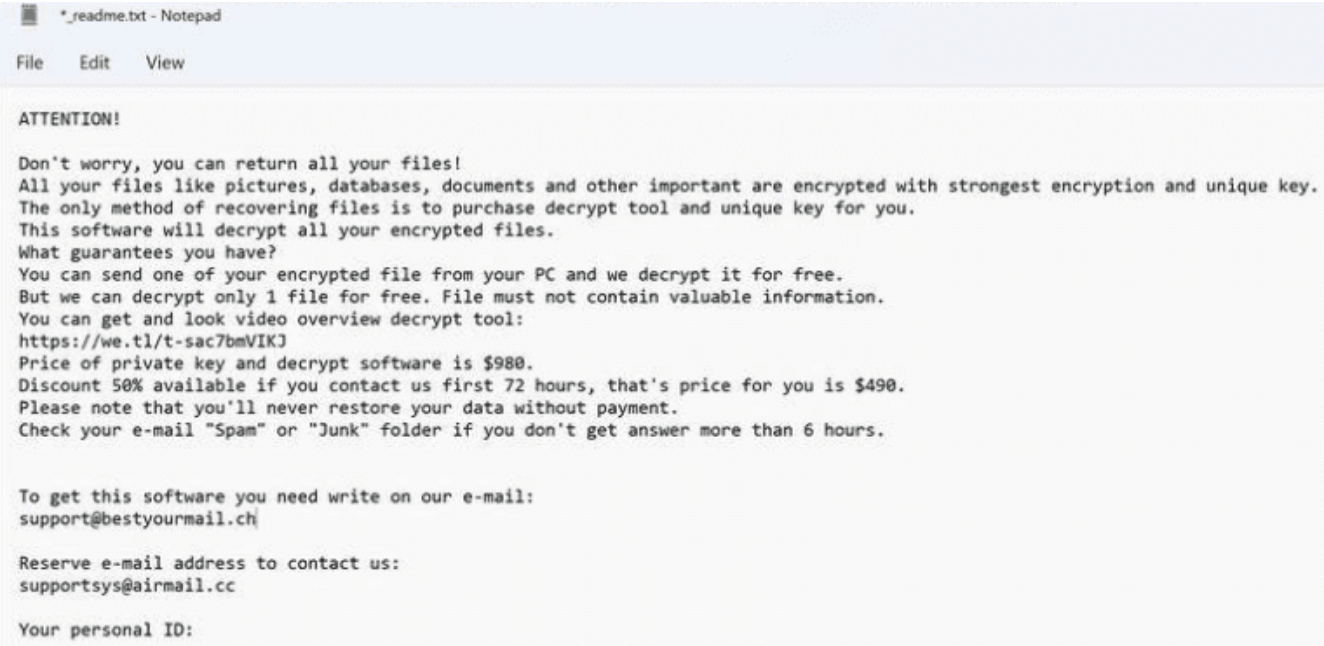
`[2026-04-03 17:14:48]` File encryption phase

The ransomware transitions into its impact phase, initiating file encryption across the system.

The malware encrypts user files and appends the `.qual` extension. For user *mario*, the following files were affected:

- `dummy.pdf`
- `file-sample_500kB.doc`

A ransom note (`_readme.txt`) is dropped into multiple directories:



*_readme.txt - Notepad

File Edit View

```
ATTENTION!

Don't worry, you can return all your files!
All your files like pictures, databases, documents and other important are encrypted with strongest encryption and unique key.
The only method of recovering files is to purchase decrypt tool and unique key for you.
This software will decrypt all your encrypted files.
What guarantees you have?
You can send one of your encrypted file from your PC and we decrypt it for free.
But we can decrypt only 1 file for free. File must not contain valuable information.
You can get and look video overview decrypt tool:
https://we.tl/t-sac7bmVIKJ
Price of private key and decrypt software is $980.
Discount 50% available if you contact us first 72 hours, that's price for you is $490.
Please note that you'll never restore your data without payment.
Check your e-mail "Spam" or "Junk" folder if you don't get answer more than 6 hours.


To get this software you need write on our e-mail:
support@bestyourmail.ch

Reserve e-mail address to contact us:
supportsys@airmail.cc

Your personal ID:
```

MITRE ATT&CK classification

- TA0040 (Impact)
  - T1486 (Data encrypted for impact)

Interaction with Cortex XDR honeypot

The malware also encrypted several decoy files placed by Cortex XDR, including:

- `!!!!!2598563045.pem`
- `XORXOR4069088892.jpg`
- `rMwab59312111.xlsx`
- `ZZZZZ3591597036.doc` (file mentioned by Cortex XDR in the case overview).

This indicates that the ransomware did not detect or avoid honeypot artifacts, and executed its encryption routine indiscriminately.

Conclusion

The malicious executable `d148…0701.exe` is confirmed to be a *Stop/Djvu* ransomware variant. During the intrusion, it:

- performed process hollowing to evade detection;
- established redundant persistence via:
  - HKCU Run key modification
  - scheduled task creation
- escalated privileges through a UAC prompt;
- contacted a C2 server to retrieve the RSA public key and victim ID;
- executed its encryption routine, impacting both user files and honeypot decoys.

The attack chain demonstrates a structured, multi-stage execution flow typical of *Stop/Djvu* families.